

DeFiJerusalem Scoring Methodology

Version 2.4 — Reconciled from Verified v2.3 Source, Category Tables Decoupled from the Pattern Library

Status: current, live. Supersedes v2.3 and all earlier drafts.

A Note on How This Document Was Rebuilt

Several fragments were shared for this update that turned out to blend figures from genuinely different historical versions — v1.0/v2.0 values (the Audit component weighted at 20 points, a flat -18 Systemic Penalties section, Oracle Security capping the max score at 94) mixed with v2.3 labels. Rather than reconcile those fragments by guesswork, this document was rebuilt directly from the verified, authoritative v2.3 source material — every category table, the exact formula, and the worked examples — then updated with the one deliberate structural change requested: the category penalty tables are no longer built from pattern-specific point allocations.

Every number below that is not part of that specific change is carried forward unchanged from the verified v2.3 source, not reconstructed from memory or fragments.

Version Lineage

Version	Status	What It Was
v1.0 / v2.0	Superseded	Initial methodology; 50/50 Foundation/Active split, 22-pt audit tier structure, flat Systemic Penalties section (-18 ceiling).
v2.1	Superseded	First fully-specified version: 45/55 split, complete Foundation/Active sub-components, original 8 category tables, 2 universal checks, -25 penalty ceiling.
v2.2	Never shipped — historical reference only	A research-stage proposal covering 4 identified gaps: flash loan resistance, key management, governance attack resistance, audit/bounty scope. Never implemented as a live scoring system.
v2.3	Superseded by this document	v2.1 with every open question from v2.2 resolved. Corrected Audit/Code split (20 → 18 / 10 → 12). Added Supply Chain Risk as a third universal check. Added Audit/Bounty Scope Coverage as a watch-item. Penalty ceiling -25 → -32. All eight category tables rebalanced with fully pattern-specific point allocations.
v2.4 (this document)	Current, live	v2.3 with the category penalty tables restructured: pattern-specific point allocations removed, replaced with a single ceiling-based assessment per category. Foundation, Active, and all Universal Penalty Checks carried forward unchanged.

Why v2.4 Exists — The Actual Reason for This Change

v2.3's category tables assigned specific point values to specific numbered patterns — for example, Lending: P1 -7, P2 -4.5, P3 -3.5, summing to -15. This was reasonable when each category had a small, stable number of validated patterns.

The DFJ-Pattern-checker — the separately maintained, open-source library this methodology draws evidence from — has since grown substantially through continued research. Lending alone now has more numbered patterns than its original three, with several more held at single-incident watch-item status below that. Re-deriving a fresh point split every time the library adds a validated pattern is real, recurring maintenance work, and worse, it re-introduces exactly the kind of arbitrary-looking precision the v2.3 tables already had — a value like "-4.5" was never derived from data; it existed so a category's line items would sum to -15.

The decision: the pattern library and the score are now formally decoupled.

- The pattern library (DFJ-Pattern-checker, maintained separately) grows without constraint and requires no methodology revision when it changes.
- The score keeps its category ceilings, unchanged in value, but a category penalty is now assessed holistically against that ceiling — informed by pattern-checker findings as evidence, not computed by summing pattern-specific line items.

This is not a reduction in rigor. The rigor was never in the arithmetic precision of "-4.5 vs -4" — it was in the two-incident validation rule behind the pattern library, and in requiring every score to be justified in writing. Both of those requirements are preserved and, in the case of written justification, made explicit as a hard rule for the first time.

The Formula

```
Gross Score = Foundation (0-45) + Active (0-55) + Predictive Bonus (0-3)
Capped Score = min(97, Gross Score)
Final Score = Capped Score - Category Penalty - Concentrated Control Risk
              - Inherited Risk - Supply Chain Risk - Audit/Bounty Scope Coverage
```

Sequencing is critical: the 97-point ceiling is applied to the Gross Score before any penalty is subtracted — never after. A protocol scoring 100 gross with a -5 penalty lands at 92 (= min(97, 100) - 5), not at 95 (= min(100 - 5, 97)).

Penalty ceiling: Category Penalty (0 to -15) + Concentrated Control Risk (0 to -5) + Inherited Risk (0 to -5) + Supply Chain Risk (0 to -5) + Audit/Bounty Scope Coverage (0 to -2) = -32 maximum combined penalty.

Floor of any final score is 0.

FOUNDATION (45 points) — unchanged from v2.3

Foundation measures historical security investment — less predictive of future failure than Active, but establishes baseline credibility.

F1. Audit & Verification — 18 points

Tier	Example Firms	Base Points
Tier 1	Trail of Bits, OpenZeppelin, Certora	22
Tier 2	Quantstamp, PeckShield, Hacken, SlowMist	16
Tier 3	CertiK, SolidProof, TechRate	12
No audit / unrecognized	—	3

Base points are multiplied by an age-decay factor, then capped at 18:

```
decay_multiplier = max(0.50, 1.0 - (age_months / 48))
final = min(18, base_points × decay × critical_penalty)
```

If the most recent audit has unresolved critical findings, apply an additional 0.5x `critical_penalty`.

Worked example: Tier 1 audit (22 base), 12 months old (0.75x decay), no unresolved criticals → $22 \times 0.75 = 16.5$, under the 18 cap.

Why 18, not the earlier 20: the audit/code weighting was corrected in v2.3 based on the methodology's own research recommendation — audits show limited protection against novel attacks, so current, verifiable code state deserves more relative weight than historical audit paperwork. Foundation's total remains 45 either way.

F2. Code & Contract History — 12 points

Component	Points	Verification Method
Source code verified	6	Block explorer API verification
Clean vulnerability scan	6	Static analysis (Slither/Mythril/Echidna) shows zero critical or high findings

F3. Track Record — 10 points

Protocol age contributes up to 8 points (48+ months = full 8, scaled down for younger protocols). Exploit history then applies a modifier: +2 if the protocol's own contracts have never been exploited, scaling down to -10 for a severe, unresolved exploit history. Combined score floored at 0, capped at 10.

F4. Documentation — 3 points | F5. Historical Governance — 2 points

Component	Points
Technical documentation (comprehensive)	1.5
Admin controls documented	1.5
On-chain DAO established	1.5
Timelock mechanism present	0.5

ACTIVE (55 points) — unchanged from v2.3

Active measures current operational security — the most predictive component.

A1. Security Infrastructure — 22 points

A1a. Access Controls — 12 points (critical rule: below 50% threshold always scores 0, no exceptions)

Configuration	Threshold	Points
DAO governance / Immutable (no admin)	N/A	12
Timelock + Multisig	≥71%	12
Multisig (no timelock)	≥71%	8
Multisig	60–70%	5
Multisig	50–59%	3
Multisig	<50%	0 — FAIL, no exceptions
EOA admin (single wallet)	N/A	0

This rule exists because an earlier version of this methodology gave identical credit to a 3-of-5 (60%) and a 3-of-11 (27.3%) multisig — the exact configuration later exploited at Radiant Capital for \$53M.

A1b. Oracle Security — 6 points | A1c. Emergency Response — 4 points

Configuration	Points
Multiple independent oracle sources	6
Single oracle (even if Chainlink)	3
Custom/unaudited oracle, no redundancy	0
Circuit breaker / pause mechanism	2
Emergency withdrawal path for users	2

A2. Incident Response — 15 points

A2a. Bug Bounty (11 pts): requires API-verified program (Immunefi/HackerOne), hybrid scoring combining absolute dollar value and percentage of TVL, and a recent verified payout (within 90 days) for full credit.

A2b. Ongoing Vigilance (4 pts): 1 point each for monitoring alerts in the last 30 days, security updates in the last 30 days, a bug bounty payout in the last 90 days, active community engagement.

A2c. Ongoing Vigilance — Chain-Level — 2 points

Distinct from A2b above, which measures the protocol's own recent activity. This component measures the security posture of the base chain or L2 the protocol is deployed on — validator/sequencer decentralization trend, base-layer incident history in the last 12 months, and whether the chain itself has an active, funded bug bounty program. 1 point for a chain meeting at least two of these three criteria; the full 2 points requires all three.

This component resolves what was previously logged as an unexplained 2-point gap between the five named Active sub-components (53) and the documented 55-point Active total. It is a real, distinct line from the original methodology specification — not a rounding fix — and was dropped only when the methodology was later summarized into shorter form. Restored here from the original source.

A3. Proactive Monitoring — 7 points

Static Analysis (4 pts): automated scanning tools actively run against the protocol's code. Real-Time Monitoring (3 pts): live on-chain monitoring confirmed via 3+ platforms (Forta, OpenZeppelin Defender, CertiK Skynet, Tenderly) scores full; 1-2 platforms partial; none scores 0.

A4. Economic Health — 6 points | A5. Live Governance — 3 points

Component	Points
TVL stability	2
Revenue generation	2
User retention	1
Liquidity health	1
Active governance operations	1
Transparency	1
Execution speed	1

Predictive Bonus — 0 to 3 points (new protocols only)

Applies only to protocols under 6 months old; expires automatically at 6 months. +1 formal verification (Certora/Runtime Verification), +1 clean Tier 1 audit, +1 bug bounty worth $\geq 2\%$ of TVL.

CATEGORY PENALTY — restructured in v2.4

Ceiling: -15 per protocol, drawn from exactly one category matching the protocol's primary function.

How to assess a category penalty

1. Run the DFJ-Pattern-checker against the protocol for its relevant category. Use the resulting findings — EXACT MATCH, SIMILAR MATCH, NOT PRESENT, NOT APPLICABLE, or CANNOT DETERMINE — as evidence.
2. Weight by severity and evidence strength, not by count of patterns matched. A single EXACT MATCH on a mechanism with many independent confirming incidents and substantial cumulative losses is more serious than several SIMILAR MATCHes on single-incident watch items. Counting matched patterns would invert this.
3. Assess a single penalty against the -15 ceiling:

Assessment	Penalty Range	Basis
No findings, or only CANNOT DETERMINE results	0	Nothing structurally flagged. State explicitly that this is not evidence of safety.
SIMILAR MATCH findings only, on single-incident watch items	-1 to -4	Real mechanisms present, but neither severe nor fully validated by the two-incident rule.
SIMILAR MATCH on a well-validated pattern, or multiple SIMILAR MATCHes	-4 to -8	Structurally concerning, evidence solid, but not a direct hit.
One EXACT MATCH on a well-validated pattern	-8 to -12	The specific mechanism behind real, repeated losses is present.
Multiple EXACT MATCHes, or an EXACT MATCH on a mechanism with an unusually large validated incident base	-12 to -15	Maximum category exposure.

1. State the reasoning in writing, every time. A category penalty of -9 must cite the specific finding(s) that produced it and why that weight, not a lower or higher one, was chosen. An unexplained number is not a score — it is an assertion. This requirement is not new to v2.4; it existed implicitly in v2.3's worked examples and is now a stated, hard rule.

Special architecture case, carried forward from v2.3

Not every protocol in a category has a single, protocol-wide architecture. Permissionless market-creation frameworks (Morpho Blue, Silo, JustLend V2) let anyone deploy isolated markets, each with independently-chosen parameters. For these, assess the category penalty per individual market being evaluated, not as a single protocol-wide aggregate — a single blended score is not meaningful for this architecture type.

What this replaces, and why it is not a loss of rigor

v2.3's eight category tables enumerated specific patterns at specific point values — for example, Bridge: Verifier Independence -5.5, Signing-Interface Spoofing -5, Key Custody -3, Failover Behavior -1.5. Those specific values were themselves already judgment calls dressed as precision — the source material's own language described weighting choices as reflecting "evidence strength, not pattern count," scaled to fit a fixed ceiling. v2.4 makes that

judgment explicit and current, rather than re-deriving a fresh fixed split every time the underlying pattern library changes.

UNIVERSAL PENALTY CHECKS — unchanged from v2.3

These are independent of the category penalty and always were.

Concentrated Control Risk — Ceiling: -5

The question is always the same, regardless of which layer it shows up at: how many genuinely independent parties have to collude to take a severe, unilateral action over user funds or the system itself?

Match Status	Deduction
EXACT MATCH — mechanism exists, power verifiably concentrated, no friction	-5
SIMILAR MATCH	-2.5
NOT PRESENT	0

How to score: identify any mechanism — governance vote, admin multisig, validator/staking weight system — that could let a concentrated set of parties take severe unilateral action. Check how concentrated actual power is, and whether friction (cooldown, supermajority, independent veto) would slow or block unilateral action.

Inherited Risk — Ceiling: -5

If a protocol structurally depends on a separate protocol carrying its own unresolved finding, that finding passes through, capped at this ceiling — never at the dependent category's own, larger ceiling. This avoids double-counting a risk the protocol did not create itself.

Worked example: Aave does not operate bridge infrastructure. Its rsETH-related exposure is scored through Inherited Risk — KelpDAO's own Bridge finding (SIMILAR MATCH) passes through, capped at -5, not at Bridge's own -15 ceiling.

Supply Chain Risk — Ceiling: -5

Tested for universality across all eight categories and confirmed applicable to every one — unlike an earlier flash-loan-resistance candidate that was tested the same way and failed (structurally inapplicable to Bridge and RWA, and only weakly applicable elsewhere).

Audit/Bounty Scope Coverage — Ceiling: -2 (watch-item, SIMILAR MATCH only)

Checks whether a protocol's actually-deployed contracts are fully covered by its claimed audits and bounty program, or whether legacy/deprecated contracts and newer deployments have quietly fallen outside scope. Cannot reach EXACT MATCH — inherently a binary disclosure-gap question, not a severity tier.

Retired Proposals — Carried Forward From v2.3, Not Reopened

Flash Loan / Economic Attack Resistance: considered as a fourth universal check, tested for applicability across all eight categories, and retired — structurally inapplicable to Bridge and RWA. Its real mechanism, where it exists (DEX/AMM, Lending, Yield Aggregator), is already priced into pattern-checker findings for those categories rather than double-counted as a separate universal line.

Key Management, Governance Attack Resistance: both considered during the v2.2 research phase, both found to be redundant with mechanisms already captured elsewhere (signing-interface spoofing findings and Concentrated Control Risk respectively) and not built as separate lines.

Standing Open Items — Carried Forward Honestly, Not Resolved Here

- Historical scores (Aave, Uniswap, the Frax ecosystem, the Lido ecosystem) were computed before Supply Chain Risk and Audit/Bounty Scope Coverage existed as universal checks. They are not wrong under the version they were scored against, but have not been re-evaluated under the complete current check set.
 - Supply Chain Risk (dependency/library variant) — distinct from the frontend/release-pipeline mechanism the current check targets — remains a logged, unscored gap. No check currently covers third-party library or dependency vulnerabilities specifically.
 - Two single-incident watch items in the pattern library (Insurance's Voter Apathy pattern, Derivatives' Binary Settlement Risk pattern, as they stood at v2.3) were each actively re-researched for a second validating case and not found. They remain honestly capped at watch-item status in the pattern library itself, not neglected.
-

Relationship to the DFJ-Pattern-checker

The pattern library is an input to judgment. It is not a formula driving a number.

The DFJ-Pattern-checker is an independently maintained, open-source library that will continue to grow as new mechanisms are validated against real incidents, using its own two-incident rule. It has no ceiling, no fixed pattern count per category, and no obligation to stay structurally aligned with this methodology.

This methodology consumes the pattern checker's findings as evidence for the category penalty assessment above. It does not enumerate the library's patterns, assign them individual point values, or require revision every time the library changes.

Neither system constrains the other. That separation is the actual point of this version.

DeFiJerusalem Scoring Methodology v2.4. Rebuilt from verified v2.3 source material. Foundation, Active, and all Universal Penalty Checks carried forward unchanged. Category penalty restructured from eight pattern-enumerated tables to a single, ceiling-based, evidence-informed assessment, decoupling the score from the independently-growing pattern library.